VERTRAULICH · TISCHLEREI BEISPIEL GMBH (FIKTIV)

Bericht zur IT-Sicherheitsberatung nach DIN SPEC 27076

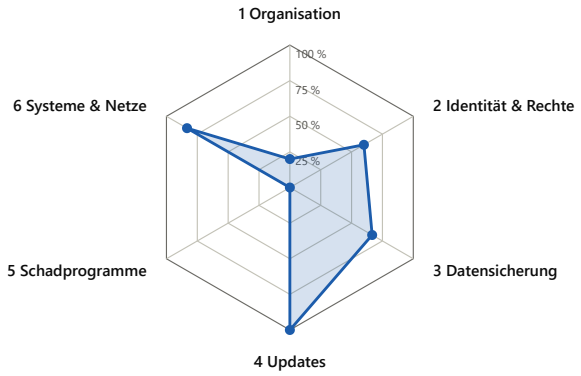
Tischlerei Beispiel GmbH (fiktiv) · Prüfung 1 · Interview am 14.10.2026

Teil A – Ergebnis nach DIN SPEC 27076

Ergebnis

Betrieb	Tischlerei Beispiel GmbH (fiktiv) · Musterweg 1, 12345 Musterstadt
Interview	14.10.2026
Berater	Beraterin Beispiel
Teilnehmende	Erika Beispiel (Geschäftsführung), Jonas Beispiel (IT im Betrieb), IT-Service Muster (IT-Dienstleister)

Statuswert: **18 von 37 Punkten** (49 %)



Ergebnis je Themenbereich

Themenbereich	Punkte	Höchstens	Anteil
1 Organisation & Sensibilisierung	2	10	20 %
2 Identitäts- und Berechtigungsmanagement	3	5	60 %
3 Datensicherung	4	6	67 %
4 Patch- und Änderungsmanagement	5	5	100 %
5 Schutz vor Schadprogrammen	−1 (zählt als 0)	5	0 %
6 IT-Systeme und Netzwerke	5	6	83 %

Nicht erfüllte TOP-Anforderungen

- 1.2 Beschäftigte erkennen Phishing und Betrugsversuche
- 5.1 Makros und aktive Inhalte sind abgeschaltet

Die fünf wichtigsten Maßnahmen

1. Beschäftigte erkennen Phishing und Betrugsversuche (bis 28.10.2026)
2. Makros und aktive Inhalte sind abgeschaltet (bis 28.10.2026)
3. Notfallplan für IT-Ausfälle und Angriffe (bis 12.01.2027)
4. Überblick über IT, Daten und Dienstleister (bis 12.01.2027)
5. Zweiter Faktor für Zugänge aus dem Internet (bis 12.01.2027)

Der Check ist keine Zertifizierung.

Ergebnis je Anforderung

Nr.	TOP	Kurzbezeichnung	Ergebnis	Punkte	Begründung
Themenbereich 1: Organisation & Sensibilisierung					
1.1	TOP	Geschäftsführung verantwortet die Informationssicherheit	Erfüllt	3	Inhaberin kümmert sich selbst; Budget für IT jährlich eingeplant; IT-Service berichtet vierteljährlich
1.2	TOP	Beschäftigte erkennen Phishing und Betrugsversuche	Nicht erfüllt	−3	bisher keine Schulung; Phishing nur aus den Medien bekannt; keine Meldestelle festgelegt
1.3		Zuständigkeit für IT-Sicherheit ist geregelt	Erfüllt	1	Werkstattleiter zuständig, Vertretung durch IT-Service Muster; Aushang im Büro
1.4		Notfallplan für IT-Ausfälle und Angriffe	Nicht erfüllt	0	kein Notfallplan; Nummer des IT-Service nur im Handy der Inhaberin
1.5		Regeln für Homeoffice und mobiles Arbeiten	Erfüllt	1	zwei Beschäftigte zeitweise im Homeoffice; Regeln schriftlich und unterschrieben
1.6		Überblick über IT, Daten und Dienstleister	Nicht erfüllt	0	keine Übersicht; Geräte und Online-Dienste kennt nur der IT-Service
Themenbereich 2: Identitäts- und Berechtigungsmanagement					
2.1		Persönliche Benutzerkonten für alle	Erfüllt	1	eigene Konten an allen Büroarbeitsplätzen; Werkstatt-PC mit begründetem Sammelkonto
2.2		Sichere und verschiedene Passwörter	Erfüllt	1	Passwortmanager seit 2025; Regeln allen bekannt
2.3		Zweiter Faktor für Zugänge aus dem Internet	Nicht erfüllt	0	E-Mail und Cloud-Ablage nur mit Passwort; Online-Banking mit App-Freigabe
2.4		Rechte nur so weit wie nötig, Administration getrennt	Nicht erfüllt	0	alle Büro-Konten mit Administratorrechten
2.5		Zugänge werden beim Austritt entzogen	Erfüllt	1	Checkliste für Austritte vorhanden, zuletzt im Juni genutzt
Themenbereich 3: Datensicherung					
3.1	TOP	Regelmäßige Datensicherung	Erfüllt	3	tägliche Sicherung auf NAS; Fehlermeldung per E-Mail an IT-Service Nachweis: Sicherungsprotokoll der letzten Woche gesehen
3.2		Alle wichtigen Daten sind in der Sicherung	Erfüllt	1	Server, Postfächer und Cloud-Ablage in der Sicherung
3.3		Eine Sicherung liegt getrennt und geschützt	Nicht erfüllt	0	Sicherung nur auf dem NAS im Serverraum; keine getrennte Kopie
3.4		Wiederherstellung wird erprobt	Nicht erfüllt	0	Wiederherstellung nie getestet
Themenbereich 4: Patch- und Änderungsmanagement					
4.1	TOP	Updates werden zeitnah eingespielt	Erfüllt	3	automatische Updates auf allen PCs; Router und NAS monatlich durch IT-Service

Nr.	TOP	Kurzbezeichnung	Ergebnis	Punkte	Begründung
4.2		Keine Systeme ohne Herstellerunterstützung	Erfüllt	1	keine veralteten Systeme; alter CNC-Rechner ohne Netzanbindung
4.3		Software kommt nur aus geprüften Quellen	Erfüllt	1	Installationen nur durch IT-Service
Themenbereich 5: Schutz vor Schadprogrammen					
5.1	TOP	Makros und aktive Inhalte sind abgeschaltet	Nicht erfüllt	−3	Makros für alle Dateien erlaubt; Kalkulationsvorlagen nutzen Makros
5.2		Virenschutz auf allen Rechnern und Servern	Erfüllt	1	Microsoft Defender auf allen PCs aktiv und überwacht Nachweis: Übersicht im Defender-Portal gezeigt
5.3		Eingehende E-Mails werden gefiltert	Erfüllt	1	Spam- und Schadprogrammfilter des E-Mail-Anbieters eingeschaltet
Themenbereich 6: IT-Systeme und Netzwerke					
6.1		Firewall schützt das Netz des Betriebs	Erfüllt	1	Router mit Firewall, keine Portfreigaben
6.2		WLAN ist verschlüsselt, Gäste sind getrennt	Erfüllt	1	WPA3; eigenes Gäste-WLAN für Kunden
6.3		Fernzugriff und Fernwartung sind abgesichert	Nicht erfüllt	0	Fernwartungsprogramm des IT-Service dauerhaft aktiv, ohne Freigabe je Sitzung
6.4		Smartphones und Tablets sind geschützt	Erfüllt	1	zwei Firmenhandys mit PIN, Verschlüsselung und Fernlöschung
6.5		Geräte ohne voreingestellte Zugangsdaten	Erfüllt	1	Standardpasswörter von Router, NAS und Drucker geändert
6.6		Rechner sind gegen fremden Zugriff gesperrt	Erfüllt	1	Bildschirmsperre nach 5 Minuten; Laptops mit BitLocker

Handlungsempfehlungen

1. **1.2 Beschäftigte erkennen Phishing und Betrugsversuche** · Priorität 1 (Sofort) · Frist 28.10.2026 · TOP
   Alle Beschäftigten zu Phishing, Betrugsanrufen und dem sicheren Umgang mit E-Mail einweisen, neue Beschäftigte gleich zu Beginn. Die Schulung mindestens jährlich wiederholen und eine feste Stelle für Verdachtsmeldungen benennen.
2. **5.1 Makros und aktive Inhalte sind abgeschaltet** · Priorität 1 (Sofort) · Frist 28.10.2026 · TOP
   Makros zentral oder an jedem Rechner standardmäßig sperren, besonders in Dateien aus dem Internet. Benötigte Makros nur aus vertrauenswürdigen Speicherorten oder mit Signatur zulassen.
3. **1.4 Notfallplan für IT-Ausfälle und Angriffe** · Priorität 2 (Zeitnah) · Frist 12.01.2027
   Einen Notfallplan auf ein bis zwei Seiten erstellen: Ansprechpartner mit Telefonnummern, Sofortmaßnahmen bei Verdacht auf einen Angriff, Meldewege und Ersatzlösungen für die wichtigsten Abläufe. Ausgedruckt aufbewahren und einmal im Jahr durchspielen.
4. **1.6 Überblick über IT, Daten und Dienstleister** · Priorität 2 (Zeitnah) · Frist 12.01.2027
   Eine einfache Übersicht anlegen und jährlich prüfen: Geräte, Programme, Online-Dienste mit Vertragspartner, Speicherorte wichtiger Daten und externe Zugänge. Sie ist die Grundlage für Updates, Datensicherung und Notfallplan.
5. **2.3 Zweiter Faktor für Zugänge aus dem Internet** · Priorität 2 (Zeitnah) · Frist 12.01.2027
   Für E-Mail, Cloud-Dienste, Fernzugänge und Administratorkonten die Anmeldung mit zweitem Faktor einschalten, mit den wichtigsten Zugängen beginnen und die Wiederherstellungscodes sicher verwahren.
6. **2.4 Rechte nur so weit wie nötig, Administration getrennt** · Priorität 2 (Zeitnah) · Frist 12.01.2027
   Zugriffsrechte nach Aufgaben ordnen und überzählige Rechte entfernen. Administratorrechte auf wenige Personen beschränken und dafür getrennte Konten einrichten, die nicht für E-Mail und Internet genutzt werden.
7. **3.3 Eine Sicherung liegt getrennt und geschützt** · Priorität 2 (Zeitnah) · Frist 12.01.2027
   Zusätzlich zur laufenden Sicherung eine Kopie anlegen, die nach dem Sichern vom Netz getrennt oder unveränderbar gespeichert wird, und sie an einem anderen Ort aufbewahren, etwa nach der 3-2-1-Regel.
8. **3.4 Wiederherstellung wird erprobt** · Priorität 2 (Zeitnah) · Frist 12.01.2027
   Mindestens einmal im Jahr eine Wiederherstellung testen, für einzelne Dateien und für ein ganzes System. Dauer und Probleme notieren und den Notfallplan danach anpassen.
9. **6.3 Fernzugriff und Fernwartung sind abgesichert** · Priorität 2 (Zeitnah) · Frist 12.01.2027
   Fernzugänge auf ein VPN oder einen geschützten Dienst mit zweitem Faktor umstellen und direkte Portfreigaben, etwa für Remotedesktop, schließen. Fernwartung nur nach Freigabe im Einzelfall erlauben und protokollieren.

Teil B – Prüfung von außen (Zusatz, nicht Teil der DIN SPEC 27076)

Zeitpunkt	13.10.2026, 11:15
Domain	example.com
Modus	Browser: nur DNS-Prüfungen
DNS-Anbieter	Cloudflare
Bestätigung	Beraterin Beispiel (vom Inhaber beauftragt), 13.10.2026, 11:15

> Ich bestätige, dass ich für die Domain example.com verantwortlich bin oder vom Inhaber mit dieser Prüfung beauftragt wurde. Die Prüfung ruft nur öffentliche DNS-Einträge, die Startseite und zwei Standarddateien ab, so wie es ein Besucher oder ein Mailserver auch tut.

⚠ 2 Warnungen ⓘ 2 Hinweise ⓘ 4 Informationen ◌ 13 nicht geprüft

E-Mail

ⓘ Information **Mailserver (MX)**: Mailserver eingetragen

```
10 mail.example.com
```

Die MX-Einträge nennen die Server, die E-Mails für die Domain annehmen. Die Zahl davor legt die Reihenfolge fest: Absender versuchen kleinere Zahlen zuerst.

⚠ Warnung **SPF**: SPF ohne klare Regel für fremde Server

```
v=spf1 mx a ?all (2 DNS-Abfragen)
```

Der Eintrag endet mit „?all“ oder hat kein „all“. Empfänger erfahren so nicht, dass E-Mails von nicht genannten Servern verdächtig sind.

Maßnahme: Den Eintrag mit „-all“ abschließen, sobald alle berechtigten Versender genannt sind; übergangsweise mit „~all“.

⚠ Warnung **DMARC**: DMARC beobachtet nur, ohne Berichte

```
v=DMARC1; p=none
```

„p=none“ bittet Empfänger nur um Beobachtung. Ohne Berichtsadresse (rua) erfährt aber niemand etwas davon; der Eintrag schützt so nicht.

Maßnahme: Eine Berichtsadresse eintragen (rua=mailto:...), die Berichte auswerten und die Richtlinie danach auf quarantine oder reject erhöhen.

ⓘ Information **DKIM**: DKIM ohne Selektor nicht prüfbar

```
kein Selektor bekannt
```

DKIM-Schlüssel stehen unter einem Namen (Selektor), den man von außen nicht erraten kann. Ohne bekannten Selektor wird DKIM nicht geprüft; er lässt sich im Schritt Betrieb eintragen.

ⓘ Information **MTA-STS**: Kein MTA-STS

```
kein MTA-STS-Eintrag
```

MTA-STS sorgt dafür, dass andere Mailserver E-Mails nur verschlüsselt an die eigenen Server übertragen. Ohne MTA-STS ist die Verschlüsselung auf diesem Weg nicht erzwungen.

ⓘ Information **TLS-RPT**: Keine TLS-Berichte

```
kein TLS-RPT-Eintrag
```

TLS-RPT ist optional. Damit melden Absender Probleme bei der verschlüsselten Zustellung von E-Mails.

Domain

> ⓘ Hinweis **DNSSEC**: DNSSEC nicht eingerichtet
>
> `nicht signiert (kein AD)`
>
> Die Einträge der Domain sind nicht signiert. Mit DNSSEC erkennen Resolver, ob DNS-Antworten unterwegs gefälscht wurden.
>
> **Maßnahme:** DNSSEC beim DNS-Anbieter oder Registrar einschalten; viele Anbieter bieten das ohne Aufwand an.

> ⓘ Hinweis **CAA**: Keine CAA-Einträge
>
> `kein CAA-Eintrag`
>
> CAA legt fest, welche Zertifizierungsstellen Zertifikate für die Domain ausstellen dürfen. Ohne Eintrag darf das jede.
>
> **Maßnahme:** Einen CAA-Eintrag für die genutzte Zertifizierungsstelle anlegen, z. B. „0 issue "letsencrypt.org"".

Website

◌ **nicht geprüft** Nur im Windows-Programm: Weiterleitung auf HTTPS, HTTPS erreichbar, Zertifikat, TLS-Version, HSTS, Content-Security-Policy, X-Content-Type-Options, Schutz vor Clickjacking, Referrer-Policy, X-XSS-Protection, Server-Angaben, Cookies, security.txt.

Grenzen der Prüfung

Passive Prüfung von außen, nur öffentlich abrufbare Informationen. Sie findet nicht alle Schwachstellen. Nicht geprüft: Mailserver per SMTP, alte TLS-Versionen, Sperrstatus von Zertifikaten; im Browser außerdem die Website (nur im Windows-Programm).

Teil C – Maßnahmenplan

Priorität	Maßnahme	Frist	Verantwortlich	Status
1 – Sofort	Beschäftigte erkennen Phishing und Betrugsversuche Anforderung 1.2 · Organisation & Sensibilisierung · TOP	28.10.2026	Erika Beispiel	in Arbeit
1 – Sofort	Makros und aktive Inhalte sind abgeschaltet Anforderung 5.1 · Schutz vor Schadprogrammen · TOP	28.10.2026	–	offen
2 – Zeitnah	Notfallplan für IT-Ausfälle und Angriffe Anforderung 1.4 · Organisation & Sensibilisierung	12.01.2027	–	offen
2 – Zeitnah	Überblick über IT, Daten und Dienstleister Anforderung 1.6 · Organisation & Sensibilisierung	12.01.2027	–	offen
2 – Zeitnah	Zweiter Faktor für Zugänge aus dem Internet Anforderung 2.3 · Identitäts- und Berechtigungsmanagement	12.01.2027	–	offen
2 – Zeitnah	Rechte nur so weit wie nötig, Administration getrennt Anforderung 2.4 · Identitäts- und Berechtigungsmanagement	12.01.2027	–	offen
2 – Zeitnah	Eine Sicherung liegt getrennt und geschützt Anforderung 3.3 · Datensicherung	12.01.2027	IT-Service Muster	erledigt am 01.11.2026
2 – Zeitnah	Wiederherstellung wird erprobt Anforderung 3.4 · Datensicherung	12.01.2027	–	offen
2 – Zeitnah	Fernzugriff und Fernwartung sind abgesichert Anforderung 6.3 · IT-Systeme und Netzwerke	12.01.2027	–	offen
2 – Zeitnah	SPF ohne klare Regel für fremde Server (example.com) Außenprüfung: SPF · example.com	12.01.2027	IT-Service Muster	offen
2 – Zeitnah	DMARC beobachtet nur, ohne Berichte (example.com) Außenprüfung: DMARC · example.com	12.01.2027	IT-Service Muster	offen
3 – Geplant	DNSSEC nicht eingerichtet (example.com) Außenprüfung: DNSSEC · example.com	12.04.2027	–	offen
3 – Geplant	Keine CAA-Einträge (example.com) Außenprüfung: CAA · example.com	12.04.2027	–	offen

Anhang

Nicht bewertete Anforderungen

keine

Fördermöglichkeiten

Landesförderung für Digitalisierung und IT-Sicherheit prüfen (Förderdatenbank des Bundes).

- Förderdatenbank des Bundes: www.foerderdatenbank.de
- Transferstelle Cybersicherheit im Mittelstand: transferstelle-cybersicherheit.de

Bezug zum IT-Grundschutz (ISMS-Brücke)

Zuordnung der Themenbereiche zu Bausteinen des IT-Grundschutz-Kompendiums (Edition 2023) als Vorschlag für den Weg zu einem Informationssicherheits-Managementsystem. Sie ist nicht mit dem BSI abgestimmt.

Themenbereich	Bausteine (IT-Grundschutz-Kompendium, Edition 2023)
1 Organisation & Sensibilisierung	ISMS.1 Sicherheitsmanagement, ORP.1 Organisation, ORP.2 Personal, ORP.3 Sensibilisierung und Schulung zur Informationssicherheit, DER.2.1 Behandlung von Sicherheitsvorfällen, DER.4 Notfallmanagement
2 Identitäts- und Berechtigungsmanagement	ORP.4 Identitäts- und Berechtigungsmanagement
3 Datensicherung	CON.3 Datensicherungskonzept
4 Patch- und Änderungsmanagement	OPS.1.1.3 Patch- und Änderungsmanagement
5 Schutz vor Schadprogrammen	OPS.1.1.4 Schutz vor Schadprogrammen, APP.1.1 Office-Produkte
6 IT-Systeme und Netzwerke	NET.1.1 Netzarchitektur und -design, NET.2.1 WLAN-Betrieb, NET.3.2 Firewall, SYS.2.1 Allgemeiner Client, SYS.3.2.1 Allgemeine Smartphones und Tablets, OPS.1.2.5 Fernwartung
Prüfung von außen (Zusatz)	APP.3.1 Webanwendungen und Webservices, APP.3.2 Webserver, APP.5.3 Allgemeiner E-Mail-Client und -Server, CON.1 Kryptokonzept

Methodik und Grenzen

Vorgehen: Die Beratung folgt dem Vorgehen der DIN SPEC 27076 „IT-Sicherheitsberatung für Klein- und Kleinstunternehmen“: Vorgespräch, Interview zu 27 Anforderungen in sechs Themenbereichen anhand der Leitfragen der Norm, Auswertung, Bericht und Besprechung. Kurzfragen, Erläuterungen und Maßnahmen in diesem Bericht sind eigene Formulierungen des Beraters, kein Normtext.

Bewertung: Eine erfüllte Basis-Anforderung zählt 1 Punkt, eine erfüllte TOP-Anforderung 3 Punkte, eine nicht erfüllte TOP-Anforderung −3 Punkte. Teilweise erfüllte oder unklare Anforderungen gelten als nicht erfüllt. Nicht relevante Anforderungen fallen aus dem Höchstwert. Ausgewiesen wird mindestens 0 Punkte.

Momentaufnahme: Das Ergebnis beruht auf den Auskünften der Teilnehmenden am Tag des Interviews; Nachweise wurden nur stichprobenartig eingesehen. Es beschreibt den Stand zu diesem Zeitpunkt und ersetzt keine regelmäßige Überprüfung.

Kein Zertifikat, keine Rechtsberatung: Der Check ist keine Zertifizierung und kein Audit. Er bewertet keine Rechtslage, etwa nach DSGVO, NIS2 oder TDDDG.

Prüfung von außen: Teil B ist ein Zusatz und nicht Teil der DIN SPEC 27076. Gelesen werden nur öffentlich abrufbare Informationen: DNS-Einträge über einen Anbieter für DNS über HTTPS, im Windows-Programm zusätzlich Startseite,

security.txt und MTA-STS-Richtlinie. Es gab keine Portscans, keine Anmeldeversuche und keine Angriffe. Eine passive Prüfung findet nicht alle Schwachstellen. Nicht geprüft werden Mailserver per SMTP (etwa STARTTLS), alte TLS-Versionen und der Sperrstatus von Zertifikaten. Ein Virenschutz oder Proxy auf dem Rechner des Beraters kann Angaben zu Zertifikaten verfälschen.

Auftrag: Die Bestätigung in Teil B ersetzt keinen schriftlichen Auftrag. Dieser sollte die geprüfte Domain und den Zeitraum der Prüfung nennen.

Hinweis: Nummerierung und Zuordnung der Anforderungen sind noch nicht abschließend mit der DIN SPEC 27076 abgeglichen. Die Bewertung nach dem Punkteschema bleibt davon unberührt.

Abrufprotokoll

Zeit	Art	Anfrage	Ergebnis	Dauer
11:15:00	DNS	`MX example.com`	NOERROR, 1 Antwort	31 ms
11:15:00	DNS	`TXT example.com`	NOERROR, 2 Antworten	28 ms
11:15:00	DNS	`TXT _dmarc.example.com`	NOERROR, 1 Antwort	26 ms
11:15:00	DNS	`TXT _mta-sts.example.com`	NXDOMAIN	24 ms
11:15:01	DNS	`TXT _smtp._tls.example.com`	NXDOMAIN	25 ms
11:15:01	DNS	`SOA example.com`	NOERROR, 1 Antwort	27 ms
11:15:01	DNS	`CAA example.com`	NOERROR, keine Antwort	23 ms
11:15:01	DNS	`CAA com`	NOERROR, keine Antwort	22 ms

Unterschriften

Ort, Datum

Ort, Datum

Geschäftsleitung (Erika Beispiel)

Berater/in (Beraterin Beispiel)

Erstellt mit Sicherheitscheck 0.1.0-web am 11.11.2026, 03:41.